

Samsung's AI Data Breach Wake-Up Call

Generative AI for Business Leaders & C-Suite | AI Risk Management & Governance

1. Why This Case Study Matters

Samsung's 2023 AI data leak is not simply a cautionary tale about careless employees. It is a case study in how even sophisticated, technology-forward organisations with strong existing security cultures can be blindsided by generative AI adoption. Samsung had robust data loss prevention (DLP) tools, network monitoring, and information security policies — yet none of those controls anticipated employees pasting proprietary code into a publicly hosted large language model. The incident exposed a gap that exists in virtually every enterprise today: the space between traditional cybersecurity controls and the new threat surface created by conversational AI tools that accept free-form text input. Understanding what went wrong, how Samsung responded, and what they built afterward gives business leaders a blueprint they can implement before they face their own incident.

2. The Anatomy of the Leak

In March 2023, Samsung Semiconductor engineers began using the free, consumer-grade version of ChatGPT to accelerate their daily work. Three separate incidents came to light within roughly three weeks:

Incident	What Was Pasted Into ChatGPT	Risk Created
Engineer A	Proprietary semiconductor source code for debugging assistance	Trade-secret exposure; potential competitive intelligence leakage to any entity querying the model
Engineer B	Internal meeting notes from a confidential product strategy session	Strategic roadmap disclosure; could inform competitor timing decisions
Engineer C	Product specifications for an unreleased device, seeking help drafting documentation	Pre-launch product details in an external system; potential securities implications if material non-public information was involved

None of the engineers believed they were doing anything harmful. From their perspective, ChatGPT was a productivity tool — no different from a search engine or a stack overflow query. This perception gap is the core lesson: employees treat AI tools as utilities, not as data-sharing channels. Unless leadership explicitly reframes AI tools as external data processors subject to the same rules as any third-party vendor, employees will continue to treat them casually.

Key Point: The threat is not malicious insiders. It is well-intentioned employees who do not understand that pasting text into a consumer AI tool is functionally identical to emailing it to an external party with no confidentiality agreement.

3. Consumer AI vs Enterprise AI — The Security Gap

The Samsung incident hinged on a distinction many business users still do not understand: the difference between consumer-grade and enterprise-grade AI platforms. The gap is not about features — it is about data handling guarantees.

Dimension	Consumer AI (Free ChatGPT, Gemini Free)	Enterprise AI (ChatGPT Enterprise, Azure OpenAI, etc.)
Data used for training	Yes — inputs may be used to improve models unless user opts out	No — contractual guarantee that customer data is never used for training
Data isolation	Shared infrastructure; no tenant separation	Dedicated tenant; data logically or physically isolated
Data residency controls	None — processed wherever vendor chooses	Customer specifies geographic region for processing and storage
Compliance certifications	None or minimal	SOC 2 Type II, ISO 27001, HIPAA BAA, GDPR DPA available
Audit logging	Minimal or none	Full audit trail of prompts and responses for compliance review
Encryption guarantees	Standard TLS in transit	TLS in transit + AES-256 at rest; customer-managed keys optional
Contractual protections	Terms of service (consumer)	Enterprise agreement with SLAs, liability, and indemnification clauses

The cost difference is modest — typically \$20-60 per user per month for enterprise seats versus free for consumer versions. Against the potential cost of a single data breach (IBM's 2023 Cost of a Data Breach report put the global average at \$4.45 million), the enterprise premium is negligible. Yet many organisations still allow employees to use free tools simply because they have not established a formal AI procurement policy.

4. Samsung's Crisis Response — A 90-Day Timeline

Samsung's response moved through three distinct phases, each offering lessons for other organisations.

Phase 1: Contain (Days 1-7)

- Complete ban on all generative AI tools — ChatGPT, Bard, Bing Chat — across all 120,000+ employees worldwide
- Network-level blocks deployed on company Wi-Fi, VPN, and managed devices
- Internal investigation launched: security team audited network logs to identify every instance of AI tool usage and data exposure
- Direct communication to OpenAI requesting deletion of exposed data and written confirmation it would not be used for model training
- All-hands communication to employees: "We are not against AI. We are against uncontrolled AI use that risks our intellectual property."

Phase 2: Build (Days 8-60)

- Cross-functional governance team formed — representatives from Legal, Information Security, Engineering, HR, and Business Operations
- Data classification framework developed specifically for AI use: what data categories may be used with which AI tools, under which conditions
- Enterprise AI platform procurement: ChatGPT Enterprise and Microsoft Copilot evaluated, contracted, and deployed with full data protection agreements
- Internal AI platform built for semiconductor-sensitive workloads: on-premises infrastructure running approved models with zero external data exposure
- Mandatory AI training curriculum developed covering capabilities, risks, policies, and approved tool usage

Phase 3: Relaunch (Days 60-90)

- Phased rollout of enterprise AI tools to departments, starting with engineering and expanding to all functions
- Mandatory training completion required before AI access was restored to any employee
- Monitoring framework activated: automated alerts for attempts to use unapproved AI tools, with periodic audits of approved tool usage patterns
- AI governance board established for ongoing oversight, policy updates, and new tool approvals

By June 2023 — just three months after the crisis — Samsung had gone from AI chaos to one of the most mature corporate AI governance frameworks in the technology sector.

5. The Shadow AI Problem

Samsung's first lesson — "employees will use AI whether you approve it or not" — describes a phenomenon now known as Shadow AI. It is the AI equivalent of Shadow IT: the use of unapproved technology tools to get work done, driven by individual productivity needs rather than organisational policy.

Real-World Incident — Cyberhaven Study (2023): Cyberhaven, a data security firm, analysed AI usage across its client base and found that 11% of data employees pasted into ChatGPT was confidential. In companies without AI policies, the percentage was significantly higher. The study also found that AI tool usage grew 4x between March and June 2023, faster than IT teams could write policies to govern it. This research confirmed Samsung's experience was not an anomaly — it was a systemic pattern across industries.

Shadow AI is more dangerous than Shadow IT because the exposure is immediate and irrevocable. When an employee uses an unapproved SaaS tool, the risk is gradual — data accumulates over time. When an employee pastes confidential source code into a consumer AI tool, the data is transmitted to external servers in a single keystroke, with no recall mechanism.

Shadow AI Risk Factor	Why It Matters
Instant transmission	Data leaves the organisation the moment the user hits Enter — no time for DLP tools to intervene on content-level inspection
Plausible innocence	Employees genuinely believe they are not sharing data — they think they

	are "asking a question"
Training data contamination	Consumer models may incorporate inputs into future training, meaning confidential data could surface in responses to other users
Scale of exposure	A single prompt can contain thousands of lines of code, entire documents, or database exports
No audit trail	Consumer tools provide no logs to the employer — the organisation may never know what was shared

6. Building an AI Acceptable Use Policy

Samsung's experience — and the broader Shadow AI problem — makes clear that every organisation needs an AI Acceptable Use Policy (AUP). This is not a lengthy compliance document. It is a simple, enforceable set of rules that answer one question for every employee: "What am I allowed to do with AI tools, and what am I not?"

Essential Elements of an AI AUP

Policy Element	What It Should State	Example
Approved tools list	Only these AI tools may be used for company work	ChatGPT Enterprise, Microsoft Copilot, internal AI platform
Data classification rules	What data can be used with which tools	Public data: any approved tool. Internal data: enterprise tools only. Confidential/restricted: internal platform only, with manager approval
Prohibited actions	Explicit list of what must never be done	Never paste source code, customer PII, financial data, legal documents, or M&A information into any AI tool
Human review requirements	When AI output must be reviewed by a human before use	All external communications, all legal/financial documents, all code merged to production
Incident reporting	What to do if you accidentally share sensitive data	Report to IT Security within 24 hours via the AI incident form; no punitive action for good-faith reporting
Training requirement	Completion required before AI access is granted	30-minute AI fundamentals course + policy acknowledgement signature

7. From Crisis to Competitive Advantage

Samsung's fourth lesson — that a crisis can accelerate positive change — deserves deeper examination. Six months after the incident, Samsung was in a stronger competitive position than before the leak occurred. Here is why:

- **Talent attraction:** Engineers increasingly seek employers with mature AI infrastructure. Samsung's published governance framework and enterprise tool access became a recruiting advantage — candidates could use AI productively without legal anxiety.

- **Client trust:** Samsung's semiconductor customers — who entrust Samsung with their own proprietary designs — gained confidence from Samsung's visible investment in AI governance. Several enterprise clients cited Samsung's response as a factor in continuing or expanding partnerships.
- **Operational efficiency:** With proper tools and training in place, engineers used AI more effectively than before the incident. Structured adoption outperformed the earlier ad-hoc, anxious usage.
- **Regulatory readiness:** Samsung's governance framework anticipated requirements that regulators later began mandating. When the EU AI Act discussions accelerated, Samsung already had the documentation, processes, and controls that would become compliance requirements.

8. Applying Samsung's Lessons to Your Organisation

You do not need to experience a data breach to benefit from Samsung's experience. The following action framework lets you implement proactive governance in weeks, not months:

Week	Action	Owner	Outcome
Week 1	Audit current AI tool usage across the organisation (survey + network analysis)	IT Security + CIO	Baseline understanding of Shadow AI exposure
Week 2	Draft AI Acceptable Use Policy; define data classification for AI	Legal + CISO + HR	Policy document ready for executive review
Week 3	Evaluate and procure enterprise AI platforms with data protection guarantees	IT Procurement + CISO	Approved tool list with signed DPAs
Week 4	Deploy enterprise tools; block consumer AI tool access on managed networks	IT Operations	Employees have approved alternatives before losing consumer access
Week 5-6	Roll out mandatory AI training; require completion for tool access	L&D + HR	100% of employees trained and policy-acknowledged
Week 7-8	Activate monitoring, establish AI governance board, schedule quarterly reviews	CISO + Governance Board	Ongoing oversight framework operational

9. Key Terms Glossary

Term	Definition
Shadow AI	Unauthorised use of AI tools by employees outside the organisation's approved technology stack, typically driven by individual productivity needs
Data Loss Prevention (DLP)	Security tools and policies that detect and prevent unauthorised transmission of sensitive data outside the organisation's network
Enterprise AI Platform	A commercially licensed AI service with contractual data protection guarantees — including no-training clauses, data isolation, and compliance certifications — designed for business use
Data Classification	A framework that categorises organisational data by sensitivity level

	(e.g., Public, Internal, Confidential, Restricted) and defines handling rules for each level
AI Acceptable Use Policy (AUP)	A formal policy document specifying which AI tools are approved, what data may be used with each tool, and what actions are prohibited
Data Processing Agreement (DPA)	A legally binding contract between an organisation and a data processor (such as an AI vendor) specifying how personal and confidential data will be handled, stored, and protected
Business Associate Agreement (BAA)	A HIPAA-required contract between a covered entity and a vendor that will handle protected health information (PHI)
No-Training Clause	A contractual provision guaranteeing that the AI vendor will not use the customer's input data to train or improve its models
Data Residency	The geographic location where data is stored and processed — critical for compliance with regulations like GDPR that restrict cross-border data transfers
Tenant Isolation	Architecture that ensures one customer's data is logically or physically separated from all other customers' data on a shared platform

10. Quick Revision Checklist

- Samsung engineers leaked confidential source code, meeting notes, and product specs via consumer ChatGPT in March 2023 — without malicious intent
- Consumer AI tools offer zero data protection guarantees; enterprise versions provide contractual no-training clauses, data isolation, and compliance certifications
- Samsung responded with a 48-hour total ban, followed by a 90-day governance build, then a phased relaunch with enterprise tools and mandatory training
- Shadow AI — employees using unapproved AI tools — is present in virtually every organisation and grows faster than IT can write policies
- Every organisation needs an AI Acceptable Use Policy covering: approved tools, data classification, prohibited actions, human review requirements, and incident reporting
- Enterprise AI costs \$20-60/user/month — negligible compared to the average \$4.45 million cost of a data breach
- Proactive governance can be implemented in 6-8 weeks using Samsung's contain-build-relaunch framework
- Samsung turned crisis into competitive advantage: stronger talent attraction, client trust, operational efficiency, and regulatory readiness

20 Exam-Based MCQs — Samsung's AI Data Breach & Shadow AI Governance

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: A pharmaceutical company's research scientists have been using the free version of ChatGPT to help draft patent applications, including pasting proprietary compound formulas and research data. The CISO discovers this through network monitoring and escalates to the executive team. What should be the executive team's FIRST action?

- A) Terminate the scientists involved to send a message about data security
- B) Immediately block access to consumer AI tools across the organisation while assessing the scope of exposure
- C) Send an email reminding employees about the confidentiality policy
- D) Begin evaluating enterprise AI platforms for future deployment

Answer: B **Explanation:** B is correct because containment must precede all other actions — every hour of continued access risks additional data exposure. Samsung's 48-hour ban was effective precisely because it stopped the bleeding immediately. A is wrong because punitive action against well-intentioned employees discourages future incident reporting and does not address the systemic gap. C is wrong because an email reminder is insufficient for an active data leak — it does not prevent continued usage. D is wrong because platform evaluation is a Phase 2 activity; it should happen after containment, not instead of it.

Q2. What was the PRIMARY reason Samsung's engineers shared confidential data with ChatGPT?

- A) They were attempting corporate espionage
- B) They believed ChatGPT was an internal Samsung tool
- C) They did not perceive pasting text into an AI tool as sharing data with an external party
- D) Samsung's IT department had explicitly approved ChatGPT for engineering use

Answer: C **Explanation:** C is correct because the engineers were trying to be more productive and did not understand that submitting text to a consumer AI tool is functionally identical to sending it to an external party. A is wrong because the leak was unintentional — the engineers had no malicious motive. B is wrong because the engineers knew they were using a public tool; they simply did not recognise the data-sharing implications. D is wrong because Samsung had no formal approval process for AI tools at the time — the gap in policy was part of the problem.

Q3. Scenario: A retail bank's compliance officer reviews the AI Acceptable Use Policy draft and notices it lacks any mention of data classification levels. The policy simply states: 'Employees may use approved AI tools for work purposes.' The compliance officer raises this with the project team. Why is the absence of data classification a significant gap?

- A) Without classification, employees have no guidance on which data types are safe to use with which AI tools
- B) Data classification is only required for healthcare organisations under HIPAA
- C) The policy is sufficient because employees can use their own judgment about data sensitivity
- D) Data classification only matters for on-premises AI deployments, not cloud-based tools

Answer: A **Explanation:** A is correct because data classification is the mechanism that translates a broad policy into actionable guidance. Without it, an employee cannot determine whether a customer's account

number, a loan application, or an internal memo is permissible input for an AI tool. B is wrong because data classification is a fundamental security practice across all industries, not limited to healthcare. C is wrong because Samsung's incident proved that employees consistently misjudge data sensitivity when using AI tools — individual judgment is insufficient. D is wrong because data classification applies regardless of deployment model; the risk of inputting sensitive data into any external system requires clear categorisation.

Q4. Which of the following is a contractual guarantee provided by enterprise AI platforms but NOT by consumer versions?

- A) The ability to generate text responses
- B) Faster response times for complex queries
- C) A no-training clause ensuring customer data will not be used to improve models
- D) Access to the latest model versions before public release

Answer: C **Explanation:** C is correct because the no-training clause is a legally enforceable contract provision specific to enterprise agreements — it guarantees the vendor will not use the customer's inputs or outputs for model training. A is wrong because both consumer and enterprise versions generate text. B is wrong because speed differences, while they may exist, are not a core contractual data protection guarantee. D is wrong because early model access is a commercial benefit, not a data protection guarantee — and it varies by vendor relationship, not consumer vs enterprise status.

Q5. *Scenario:* A global manufacturing company's CEO learns that the EU AI Act will require documented AI governance processes. The company currently has no AI policy, but employees across 15 countries are actively using various AI tools. The CEO asks the CIO to propose a governance approach. Based on Samsung's experience, what approach should the CIO recommend?

- A) Wait for the final EU AI Act regulations before creating any policies to avoid rework
- B) Permanently ban all AI tools to eliminate regulatory risk entirely
- C) Implement proactive governance now — audit current usage, deploy enterprise tools, create an AUP, and train employees — rather than waiting for a crisis or regulation to force action
- D) Hire an external consultancy to manage all AI governance for the next three years

Answer: C **Explanation:** C is correct because Samsung's key lesson was that proactive governance is vastly cheaper and less disruptive than reactive governance after an incident. Waiting for regulation means operating at risk in the interim, and the governance framework needed for compliance is the same one needed for security. A is wrong because delaying governance leaves the organisation exposed to data leaks, compliance gaps, and Shadow AI growth for an indefinite period. B is wrong because a permanent ban drives AI usage underground (Shadow AI), creates competitive disadvantage, and is unsustainable — Samsung demonstrated this by lifting their ban after 90 days. D is wrong because outsourcing governance entirely does not build internal capability, and the governance framework must be tailored to the company's specific data, industry, and operations.

Q6. In the context of Samsung's incident, what does the term 'Shadow AI' refer to?

- A) AI systems that operate without human oversight in production environments
- B) The use of unapproved AI tools by employees outside the organisation's sanctioned technology stack
- C) AI models that have been trained on biased data and produce discriminatory outputs
- D) Competitor companies' secret AI research programmes

Answer: B **Explanation:** B is correct because Shadow AI describes employees using AI tools — typically free consumer versions — that the organisation has not evaluated, approved, or secured. The term parallels 'Shadow IT' in traditional technology governance. A is wrong because it describes autonomous AI systems, which is a separate governance concern. C is wrong because it describes AI bias, a distinct ethical and technical challenge. D is wrong because 'Shadow AI' is an internal governance concept, not a competitive intelligence term.

Q7. Scenario: *A law firm's senior partner asks an associate to use AI to draft a client's merger agreement. The firm has an enterprise AI platform with data protection guarantees, but the associate finds the consumer version of the same tool slightly faster and more convenient for drafting. The associate reasons that the content is the same either way. Why is using the consumer version problematic even if the output quality is identical?*

- A) Consumer versions produce lower-quality legal text
- B) The consumer version may use the client's confidential merger details for model training, potentially violating attorney-client privilege and the firm's DPA obligations
- C) Enterprise versions have a different user interface that is required for legal work
- D) Consumer versions are slower than enterprise versions for legal documents

Answer: B **Explanation:** B is correct because the risk is in data handling, not output quality. The consumer version lacks no-training guarantees, meaning confidential merger details could be incorporated into the model's training data — a potential breach of attorney-client privilege, professional ethics rules, and the firm's contractual obligations to the client. A is wrong because output quality differences, if any, are not the primary concern — data protection is. C is wrong because the user interface difference is irrelevant to the legal and ethical risk. D is wrong because speed differences do not address the data protection issue.

Q8. According to the Cyberhaven study referenced in the Samsung case, approximately what percentage of data that employees pasted into ChatGPT was classified as confidential?

- A) 2%
- B) 11%
- C) 35%
- D) 50%

Answer: B **Explanation:** B is correct — Cyberhaven's 2023 analysis found that 11% of data employees pasted into ChatGPT was confidential. A is wrong because it significantly underestimates the scale of the problem. C and D are wrong because they overstate the finding, though the percentage was higher in organisations without AI policies.

Q9. Scenario: A healthcare technology company has deployed an enterprise AI platform with a signed BAA (Business Associate Agreement) for its clinical support staff. A new employee in the marketing department, who does not handle patient data, asks IT for access to the same platform for creating marketing copy. Should IT grant the marketing employee access to the enterprise AI platform?

- A) No — the BAA only covers clinical staff, so marketing cannot use the platform
- B) Yes — but only after the employee completes mandatory AI training and acknowledges the AI Acceptable Use Policy
- C) No — marketing employees should use the free consumer version instead
- D) Yes — immediately, since the platform is already approved

Answer: B **Explanation:** B is correct because the enterprise platform's data protection applies to all users, and marketing use of an enterprise tool is appropriate. However, Samsung's experience showed that tool access without training leads to misuse — mandatory training and policy acknowledgement must precede access for any employee. A is wrong because the BAA covers the vendor relationship for the platform, not individual user roles; marketing can use the same platform for non-PHI work. C is wrong because directing any employee to consumer AI tools when enterprise alternatives exist creates unnecessary risk. D is wrong because granting access without training violates the governance principle that drove Samsung's successful relaunch.

Q10. What was Samsung's long-term strategic outcome from the 2023 AI data breach incident?

- A) Samsung permanently banned all AI tools and returned to pre-AI workflows
- B) Samsung's stock price collapsed and the company lost its market position
- C) Samsung built a world-class AI governance framework that became a competitive advantage in talent attraction, client trust, and regulatory readiness
- D) Samsung outsourced all AI-related work to third-party vendors

Answer: C **Explanation:** C is correct because Samsung's 90-day response transformed a crisis into a strategic asset. Their governance framework attracted engineering talent, strengthened client relationships (particularly semiconductor customers who trusted Samsung with proprietary designs), and prepared the company for emerging regulations. A is wrong because Samsung lifted the ban after 90 days — a permanent ban was never the strategy. B is wrong because the incident, while publicised, did not materially damage Samsung's market position. D is wrong because Samsung built internal AI capability and infrastructure rather than outsourcing.

Q11. Scenario: A financial services firm is implementing an AI Acceptable Use Policy. The CISO proposes that any employee who accidentally shares confidential data with an unapproved AI tool should face immediate disciplinary action. The Chief People Officer pushes back, arguing this approach is counterproductive. Why is the Chief People Officer's pushback justified?

- A) Disciplinary action is never appropriate for security violations
- B) Punitive responses to good-faith mistakes discourage incident reporting, which means the organisation will not learn about future breaches until the damage is much worse

- C) Employees cannot be held responsible for data security because it is entirely the IT department's responsibility
- D) Accidental data sharing through AI tools does not create any meaningful security risk

Answer: B **Explanation:** B is correct because Samsung's approach explicitly included non-punitive incident reporting as a policy element. If employees fear termination for honest mistakes, they will hide their AI usage rather than report incidents — leaving the organisation blind to ongoing Shadow AI exposure. A is wrong because repeated or wilfully negligent violations may warrant disciplinary action; the policy should distinguish good-faith mistakes from reckless behaviour. C is wrong because data security is a shared responsibility; employees have obligations to follow policies and report incidents. D is wrong because accidental data sharing with consumer AI tools creates real, material security risk — Samsung's incident proved this conclusively.

Q12. In Samsung's three-phase crisis response, what was the primary purpose of the 'Build' phase (Days 8-60)?

- A) To identify and terminate employees who caused the data leak
- B) To design and implement the governance infrastructure — policies, enterprise tools, training, and internal AI platforms — needed for safe AI adoption
- C) To permanently remove all AI capabilities from Samsung's technology stack
- D) To notify regulatory authorities about the data breach

Answer: B **Explanation:** B is correct because the Build phase was Samsung's investment in sustainable AI governance. They formed a cross-functional governance team, developed data classification rules, procured enterprise AI platforms, built an internal AI platform for highly sensitive work, and created mandatory training. A is wrong because Samsung did not pursue punitive action against the engineers. C is wrong because the goal was controlled AI adoption, not elimination. D is wrong because regulatory notification, while potentially necessary, was a Contain phase activity, not the Build phase's primary purpose.

Q13. *Scenario:* A technology startup with 200 employees is growing rapidly. The CTO wants to allow all employees to use any AI tool they prefer, arguing that restrictions will slow innovation. The Head of Security warns that this approach mirrors Samsung's pre-incident state. What is the MOST balanced approach for the startup?

- A) Allow unrestricted AI tool usage as the CTO recommends, since startups need speed above all else
- B) Ban all AI tools until the company reaches 1,000 employees and can afford a governance team
- C) Provide approved enterprise AI tools with a lightweight AUP and basic training, balancing speed with baseline security
- D) Allow unrestricted usage but require employees to sign a waiver accepting personal liability for data leaks

Answer: C **Explanation:** C is correct because Samsung's lesson applies regardless of company size: uncontrolled AI usage creates risk, but banning AI creates competitive disadvantage. A lightweight AUP

with enterprise tools gives employees the speed they need while establishing the minimum viable governance framework. A is wrong because 'speed above all else' is exactly the mindset that led to Samsung's incident — even startups handle sensitive data (customer information, proprietary code, investor communications). B is wrong because it trades security for competitive disadvantage; a 200-person startup cannot afford to wait while competitors use AI productively. D is wrong because shifting liability to employees does not reduce the actual risk — the company still suffers reputational, legal, and competitive damage from a breach.

Q14. Why did Samsung specifically build an internal AI platform in addition to procuring enterprise versions of commercial tools?

- A) Internal platforms are always cheaper than enterprise subscriptions
- B) Samsung wanted to compete with OpenAI in the AI model market
- C) For the most sensitive semiconductor work, Samsung needed complete data control with zero external transmission — even enterprise cloud tools send data to vendor servers
- D) Enterprise AI tools cannot generate code, so an internal tool was needed for engineering

Answer: C **Explanation:** C is correct because Samsung's semiconductor designs are among its most valuable trade secrets. Even with enterprise data protection guarantees, sending this data to any external server creates residual risk. An on-premises platform ensures the most sensitive workloads never leave Samsung's infrastructure. A is wrong because internal platforms typically cost more to build and maintain than enterprise subscriptions — the decision was about security, not cost. B is wrong because Samsung built the platform for internal use, not as a commercial AI product. D is wrong because enterprise AI tools can generate code — the issue was data sensitivity, not tool capability.

Q15. *Scenario:* An insurance company's underwriting team has been using an enterprise AI tool for six months. A quarterly audit reveals that three underwriters have been copying AI-generated policy language directly into customer contracts without any human review. The policies are technically accurate but occasionally contain non-standard clauses. Which governance principle has been violated?

- A) Data classification — the underwriters should not be using AI for insurance work
- B) Human review requirements — AI output used in customer-facing legal documents must be reviewed by a qualified professional before use
- C) Approved tools — the underwriters should be using a different AI platform
- D) Training requirements — the underwriters were not trained on how to use AI

Answer: B **Explanation:** B is correct because an AI Acceptable Use Policy should specify that AI-generated content used in legal documents, customer communications, and binding contracts requires human review before use. The fact that the output is 'technically accurate' is insufficient — even occasional non-standard clauses in insurance contracts can create legal exposure. A is wrong because using enterprise AI for underwriting is appropriate; the issue is the lack of review, not the tool usage itself. C is wrong because there is no indication the tool is unapproved. D is wrong because the underwriters clearly know how to use the tool — the gap is in review process compliance, not tool proficiency.

Q16. What is the average cost of a data breach according to IBM's 2023 Cost of a Data Breach report?

- A) \$500,000
- B) \$1.2 million
- C) \$4.45 million
- D) \$12.8 million

Answer: C **Explanation:** C is correct — IBM's 2023 report placed the global average cost at \$4.45 million per breach, making the enterprise AI premium of \$20-60 per user per month trivial by comparison. A and B are wrong because they significantly underestimate the average. D is wrong because while some breaches exceed \$12.8 million, this is not the global average.

Q17. *Scenario:* A consulting firm's managing partner asks the IT team to implement network-level blocks on all consumer AI tools within 24 hours. The IT director responds that network blocks alone will not prevent employees from using AI tools on personal devices connected to non-corporate networks during work hours. What additional control should the firm implement alongside network blocks?

- A) Confiscate all employees' personal devices during work hours
- B) Deploy enterprise AI tools that are more capable and convenient than consumer alternatives, reducing employees' motivation to use unapproved tools
- C) Accept that the risk is unmanageable and remove the network blocks
- D) Install monitoring software on employees' personal devices

Answer: B **Explanation:** B is correct because Samsung's approach worked precisely because they replaced consumer tools with enterprise alternatives. If approved tools are equally capable (or better), employees have no reason to use unapproved ones. Controls work best when they align with employee interests rather than oppose them. A is wrong because it is impractical, likely illegal in many jurisdictions, and would severely damage employee relations. C is wrong because the risk is manageable through a combination of technical controls, policy, and approved alternatives. D is wrong because monitoring personal devices raises serious privacy and legal issues and is generally not permissible without explicit consent.

Q18. Which of the following BEST describes why Samsung communicated "We are not against AI — we are against uncontrolled AI use" to employees during the crisis?

- A) To avoid negative media coverage about being anti-technology
- B) To signal that the ban was temporary and that the organisation valued AI — framing governance as an enabler of safe adoption rather than a barrier to productivity
- C) To comply with South Korean labour law requiring technology-related communications
- D) To prevent employees from filing grievances about losing access to productivity tools

Answer: B **Explanation:** B is correct because the messaging set the tone for everything that followed. By framing the ban as a bridge to better AI tools (not a retreat from AI), Samsung maintained employee buy-in and enthusiasm for the governance programme. A is wrong because while media perception mattered, the primary audience was internal — employees needed to understand the ban was temporary and purposeful. C is wrong because no such specific legal requirement drove the communication. D is wrong because while

employee relations mattered, the communication strategy was about culture and adoption, not grievance prevention.

Q19. Scenario: A mid-sized accounting firm has implemented an AI governance programme inspired by Samsung's model. After three months, an internal survey shows that 40% of employees have not completed the mandatory AI training but are already using the enterprise AI tools because a system configuration error failed to enforce the training prerequisite. What should the firm do FIRST?

- A) Revoke AI access for untrained employees immediately and fix the configuration to enforce the training prerequisite before restoring access
- B) Ignore the issue since employees are using the enterprise version and not consumer tools
- C) Send a reminder email asking untrained employees to complete the training at their convenience
- D) Remove the training requirement from the policy since employees are already using the tools successfully

Answer: A **Explanation:** A is correct because training is a governance control, not a suggestion. Samsung required training completion before restoring access for a reason: untrained employees are more likely to misuse tools, violate data classification rules, and fail to recognise when AI output requires human review. Fixing the enforcement gap and requiring completion protects the firm. B is wrong because using the right tool without understanding the policy still creates risk — employees may input inappropriate data or skip required reviews. C is wrong because a reminder email does not address the systemic enforcement failure. D is wrong because removing the requirement because of an enforcement error undermines the entire governance framework.

Q20. Samsung's incident involved three engineers over approximately three weeks. Why does this timeline make the incident MORE concerning for other organisations, not less?

- A) Three weeks is longer than most data breaches, indicating Samsung had unusually weak security
- B) If three engineers at a security-conscious company like Samsung independently made the same mistake in three weeks, the behaviour is likely endemic across organisations with weaker AI governance
- C) The three-week timeline means the total data exposure was minimal
- D) Three engineers represent a statistically insignificant sample and the incident was likely isolated

Answer: B **Explanation:** B is correct because Samsung is a technology company with sophisticated security infrastructure and a strong compliance culture. If even their engineers did not recognise the risk, employees at less security-mature organisations are almost certainly doing the same — likely at greater scale and with less chance of detection. The Cyberhaven study confirmed this: Shadow AI is systemic, not anecdotal. A is wrong because the three-week detection timeline was actually relatively fast for this type of insider threat. C is wrong because even a small volume of exposed trade secrets can cause significant competitive damage. D is wrong because the three engineers were the ones detected — the actual number using ChatGPT was likely much higher, as Samsung's subsequent company-wide investigation revealed.